

UNIVERSIDAD INVENIO

Ingeniería en Tecnologías de Información y Comunicación Empresarial

Nombre de los estudiantes:

Alejandro Josué Rodríguez Zamora
Avril Madrigal Elizondo
Luis Alejandro Luna García
Cesar Andres Ubau Calvo

TIIT3175.2 BASE DE DATOS III

Proyecto 2 · Entregable 1
Estándar esencial para la administración de bases de datos Microsoft SQL Server

Nombre del académico:
Eric Delgado Acevedo

Tilarán, Guanacaste, 29 de agosto del 2026

Contenido

1. Objeto y campo de aplicación..... 5
1.1 Objeto..... 5
1.2 Objetivos específicos..... 5
1.3 Campo de aplicación..... 5
1.4 Ambientes cubiertos..... 5
1.5 Vigencia y revisión..... 6
2. Referencias normativas..... 6
3. Términos, definiciones y formas verbales..... 7
3.1 Términos y definiciones..... 7
3.2 Formas verbales..... 8
4. Roles, responsabilidades y separación de funciones..... 9
4.1 Administrador de bases de datos..... 9
4.2 Equipo de desarrollo..... 9
4.3 Propietario de la información..... 9
4.4 Separación de funciones..... 9
4.5 Procedimiento de excepciones..... 10
4.6 Matriz RACI..... 10
5. Seguridad y control de acceso..... 12
5.1 Creación de logins y usuarios..... 12
5.2 Uso de roles..... 12
5.3 Principio de mínimo privilegio..... 13
5.4 Cuentas personales y cuentas compartidas..... 13
5.5 Revisión y revocación periódica de accesos..... 13
5.6 Protección de credenciales..... 13
5.7 Información sensible..... 14
5.8 Auditoría de accesos y cambios administrativos..... 14
5.9 Cifrado: criterios de pertinencia..... 14
6. Respaldo, restauración y recuperación..... 16
6.1 Selección del modelo de recuperación..... 16
6.2 Tipos de respaldo y frecuencia según criticidad..... 17
6.3 Retención y ubicación de las copias..... 17
6.4 Verificación de ejecución..... 18
6.5 Pruebas de restauración..... 18
6.6 Recuperación a un punto en el tiempo..... 19
6.7 Responsables y evidencias..... 19
7. Alta disponibilidad y continuidad..... 20
7.1 Diferenciación de conceptos..... 20
7.2 Criterios de selección..... 20
7.3 Matriz comparativa de alternativas..... 21
8. Monitoreo y mantenimiento..... 21
8.1 Línea base de salud operativa..... 21
8.2 Vigilancia de capacidad..... 22
8.3 Mantenimiento preventivo..... 22
8.4 Atención de incidentes..... 22

9. Convenciones de código y gestión de cambios.....23
9.1 Nomenclatura.....23
9.2 Reglas de código T-SQL.....24
9.3 Control de versiones y despliegues.....24
9.4 Lista de verificación previa al despliegue.....25
10. Catálogo de controles.....27
11. Control de versiones y aprobación.....31
11.1 Control de versiones.....31
11.2 Aprobación.....31

Índice de tablas

Tabla 1. Ambientes cubiertos y régimen de aplicación.....6
Tabla 2. Referencias normativas y disposiciones que fundamentan.....7
Tabla 3. Términos y definiciones aplicables a este estándar.....8
Tabla 4. Formas verbales adoptadas y su valor normativo.....8
Tabla 5. Procedimiento para el registro y aprobación de excepciones.....10
Tabla 6. Matriz RACI de las actividades principales de administración de bases de datos.....11
Tabla 7. Criterios de pertinencia de las tecnologías de cifrado.....15
Tabla 8. Criterios de selección del modelo de recuperación.....16
Tabla 9. Objetivos de recuperación y estrategia mínima según criticidad.....17
Tabla 10. Responsables, frecuencias y evidencias del proceso de respaldo.....19
Tabla 11. Diferenciación entre respaldo, alta disponibilidad y recuperación ante desastres.....20
Tabla 12. Matriz comparativa de alternativas de disponibilidad y continuidad.....21
Tabla 13. Convenciones de nomenclatura de objetos de base de datos.....23
Tabla 14. Lista de verificación de código y despliegue.....26
Tabla 15. Catálogo de controles verificables del estándar.....30
Tabla 16. Control de versiones del estándar.....31
Tabla 17. Registro de elaboración, revisión y aprobación del estándar.....31

1. Objeto y campo de aplicación

1.1 Objeto

Este estándar establece los requisitos mínimos obligatorios para la administración de plataformas de bases de datos Microsoft SQL Server dentro de la organización. Su finalidad es que toda base de datos, con independencia del sistema que soporte, sea creada, protegida, respaldada, monitoreada y modificada bajo criterios uniformes, verificables y trazables.

El documento no contiene recomendaciones de carácter orientativo. Cada disposición constituye una obligación cuyo cumplimiento debe poder demostrarse mediante evidencia documental o registro técnico, en los términos que la propia disposición define.

1.2 Objetivos específicos

- Definir las responsabilidades básicas para la administración y custodia de las bases de datos.
- Establecer las reglas de acceso, mínimo privilegio, auditoría y protección de información sensible.
- Definir los criterios de respaldo, restauración, recuperación y pruebas periódicas.
- Diferenciar el respaldo, la alta disponibilidad y la recuperación ante desastres.
- Establecer los controles mínimos de monitoreo, mantenimiento y atención de incidentes.
- Definir las convenciones aplicables a los objetos de base de datos, al código T-SQL, al control de versiones y a los despliegues.
- Transformar las prácticas reconocidas del sector en controles verificables y aplicables.

1.3 Campo de aplicación

Este estándar es de aplicación obligatoria para todas las instancias de Microsoft SQL Server administradas por la organización, en cualquiera de sus ediciones y modalidades de despliegue, ya sea en servidores propios, virtualizados o en servicios de infraestructura contratados a terceros.

Quedan sujetos a él el personal con rol de administrador de bases de datos, el personal de desarrollo que produce o modifica objetos de base de datos, y los propietarios de la información almacenada en dichas plataformas.

El estándar no está vinculado a ninguna base de datos, aplicación ni unidad de negocio en particular. Cualquier implementación concreta debe poder evaluarse contra las disposiciones aquí definidas.

1.4 Ambientes cubiertos

Se reconocen tres ambientes, conforme a la tabla 1. La totalidad de las disposiciones aplica al ambiente de producción; los ambientes inferiores aplican el régimen que allí se indica.

Ambiente	Propósito	Régimen aplicable
Desarrollo	Construcción y prueba unitaria de objetos y código.	Convenciones de código y control de versiones. No debe utilizarse información real de producción sin enmascaramiento previo.

Ambiente	Propósito	Régimen aplicable
Pruebas	Validación funcional e integrada previa al despliegue.	Todas las disposiciones de producción, salvo las frecuencias de respaldo, que se reducen a la periodicidad que defina el propietario de la información.
Producción	Operación real del negocio.	Aplicación íntegra del estándar, sin más desviaciones que las excepciones aprobadas conforme al apartado 4.5.

Tabla 1. Ambientes cubiertos y régimen de aplicación.

1.5 Vigencia y revisión

1.5.1 Este estándar entra en vigencia a partir de su aprobación formal por la jefatura de Tecnologías de Información, registrada en la tabla de aprobación del apartado 11.2. Debe revisarse al menos una vez al año, o de forma anticipada ante un cambio tecnológico o un incidente que evidencie una insuficiencia normativa.

> ***Verificación:*** *Tabla de aprobación del apartado 11.2 completa y registro de revisión anual con fecha, responsable y resultado.*

1.5.2 Toda versión debe identificar número de versión, fecha de emisión, autor y naturaleza de los cambios respecto de la versión anterior.

> ***Verificación:*** *Tabla de control de versiones del apartado 11.1.*

2. Referencias normativas

Los documentos que se relacionan en la tabla 2 son indispensables para la aplicación de este estándar. Se citan con su edición y versión concretas, porque los identificadores de control que este documento invoca dependen de ellas. Se indica además qué disposiciones fundamenta cada fuente, de modo que la trazabilidad entre la fuente y el articulado sea verificable.

Este estándar selecciona principios aplicables de las fuentes citadas y los transforma en disposiciones propias. No reproduce de forma extensa el contenido de normas, benchmarks ni publicaciones protegidas.

Referencia	Alcance aportado	Disposiciones que fundamenta
Microsoft. Documentación técnica de SQL Server. Microsoft Learn. Consultada el 29 de agosto de 2026.	Modelos de recuperación, cadena de respaldos, verificación de página y de respaldo, recuperación a un punto en el tiempo, roles y permisos, alternativas de disponibilidad y sus límites por edición.	Capítulos 6 y 7; disposiciones 5.2.3, 6.4.1, 6.4.2, 8.2.2.
Center for Internet Security. CIS Microsoft SQL Server Benchmark, versión vigente para la edición desplegada. Secciones 2 Surface Area Reduction, 3 Authentication and Authorization, 4 Password Policies y 5 Auditing and Logging.	Configuración segura de la instancia, reducción de superficie de acceso, gestión de cuentas y directivas de autenticación.	Disposiciones 5.1.2, 5.4.1, 5.4.2, 5.6.2 y control DBA-SEG-02.

Referencia	Alcance aportado	Disposiciones que fundamenta
ISO/IEC 27001:2022. Sistemas de gestión de la seguridad de la información. Anexo A, controles 5.3, 5.15, 5.16, 5.17, 5.18, 8.2, 8.13, 8.15 y 8.16.	Segregación de funciones, control de accesos, gestión de identidades, derechos de acceso, respaldo de la información, registro de eventos y actividades de monitoreo.	Apartados 4.4, 4.5, 5.5, 5.8 y controles DBA-GOB-02, DBA-SEG-01, DBA-SEG-04.
ISACA. COBIT 2019. Marco de gobierno y gestión de la información y la tecnología. Objetivos APO13 Managed security, BAI10 Managed configuration, DSS04 Managed continuity y DSS05 Managed security services.	Asignación de responsabilidades, notación RACI, propiedad de la información y separación de funciones.	Capítulo 4 completo y control DBA-GOB-01.
PCI Security Standards Council. PCI DSS v4.0, requisito 10.5.1.	Plazo mínimo de conservación del historial de registros de auditoría.	Disposición 5.8.2.
ISO/IEC Directives, Part 2, novena edición, 2021. Principios y reglas para la estructura y redacción de documentos ISO e IEC.	Estructura obligatoria de un documento normativo y valor normativo de las formas verbales.	Capítulos 2 y 3; apartado 3.2.

Tabla 2. Referencias normativas y disposiciones que fundamentan.

3. Términos, definiciones y formas verbales

3.1 Términos y definiciones

Para los fines de este estándar aplican los términos y definiciones de la tabla 3. Estos términos determinan el alcance de las obligaciones que el articulado establece, por lo que su interpretación no queda a criterio del lector.

Término	Definición
Ambiente	Conjunto de instancias e infraestructura destinado a una etapa determinada del ciclo de vida de un sistema: desarrollo, pruebas o producción.
Criticidad	Clasificación que el propietario de la información asigna a una base de datos en función del impacto que la pérdida o la indisponibilidad de sus datos produce en la operación. Determina los objetivos de recuperación y la estrategia de respaldo exigibles.
Evidencia	Documento, registro o resultado de una consulta que permite determinar, en un momento posterior, si una disposición se cumplió. Debe consignar fecha y hora, la acción ejecutada y el resultado obtenido.
Excepción	Autorización formal, temporal y documentada para no aplicar una disposición de este estándar, sustituyéndola por un control compensatorio y dejando constancia del riesgo residual asumido.
Información sensible	Atributo o conjunto de atributos que el propietario de la información identifica como de acceso restringido, por su naturaleza personal, financiera, contractual o estratégica.
Línea base de salud operativa	Conjunto documentado de métricas de estado, capacidad y actividad de una instancia, capturado en un momento determinado y acompañado de su interpretación, que sirve de referencia para detectar desviaciones posteriores.

Término	Definición
Objetivo de punto de recuperación	Cantidad máxima de información, expresada en tiempo, cuya pérdida resulta aceptable ante un incidente. Determina la frecuencia mínima de los respaldos. Se abrevia RPO por sus siglas en inglés.
Objetivo de tiempo de recuperación	Plazo máximo aceptable entre la ocurrencia de un incidente y el restablecimiento del servicio de base de datos. Se abrevia RTO por sus siglas en inglés.
Propietario de la información	Responsable funcional, no técnico, de los datos que soporta una base de datos. Clasifica su criticidad, identifica la información sensible y autoriza los accesos sobre ella.
Riesgo residual	Riesgo que subsiste tras la aplicación de un control compensatorio, y que la organización acepta de forma expresa al aprobar una excepción.

Tabla 3. Términos y definiciones aplicables a este estándar.

3.2 Formas verbales

Este estándar adopta las formas verbales de la tabla 4, conforme a ISO/IEC Directives Part 2. El valor normativo de cada disposición se determina por la forma verbal empleada y no por su ubicación en el documento.

Forma	Valor normativo	Significado
debe	Requisito	Obligación de cumplimiento estricto. Su incumplimiento constituye una desviación del estándar y exige tramitar una excepción conforme al apartado 4.5. La forma negativa es «no debe».
debería	Recomendación	Curso de acción preferido entre varios posibles, sin excluir los demás. Su no aplicación no constituye desviación, pero debe poder explicarse.
puede	Permiso	Libertad expresamente concedida por este estándar. No constituye obligación ni recomendación.

Tabla 4. Formas verbales adoptadas y su valor normativo.

> **Criterio:** no se emplea el término «tiene que» ni construcciones equivalentes para expresar requisitos. ISO/IEC Directives Part 2 reserva esa forma para obligaciones externas al documento, tales como disposiciones legales o leyes naturales, y advierte expresamente contra su uso como alternativa del requisito normativo.

4. Roles, responsabilidades y separación de funciones

4.1 Administrador de bases de datos

El administrador de bases de datos, en adelante DBA, es el responsable técnico de la operación, protección y recuperabilidad de las plataformas de bases de datos. Le corresponde:

- Crear, configurar y dar de baja las bases de datos conforme a este estándar.
- Ejecutar la asignación y revocación de accesos previamente autorizados por el propietario de la información.
- Diseñar y ejecutar la estrategia de respaldo, y conducir las pruebas de restauración.
- Mantener el monitoreo y la línea base de salud operativa de las instancias.
- Aplicar los cambios en producción y conservar la evidencia de su ejecución.
- Atender los incidentes de base de datos y documentar su resolución.

4.2 Equipo de desarrollo

El equipo de desarrollo es responsable de que el código y los objetos que produce cumplan las convenciones del capítulo 9. Le corresponde:

- Entregar los scripts de implementación y de reversión, versionados y probados en un ambiente inferior.
- Documentar las dependencias de cada cambio y su impacto sobre objetos existentes.
- Solicitar los accesos que su aplicación requiera, indicando la justificación funcional de cada permiso.
- Abstenerse de ejecutar cambios directamente sobre el ambiente de producción.

4.3 Propietario de la información

El propietario de la información es el responsable funcional de los datos que soporta cada base de datos. No es un rol técnico. Le corresponde:

- Clasificar la criticidad de la información y determinar qué atributos constituyen información sensible.
- Autorizar, denegar y solicitar la revocación de los accesos sobre su información.
- Aprobar los valores de objetivo de punto de recuperación y de tiempo de recuperación aplicables a su información.
- Participar en la revisión periódica de accesos y dejar constancia de su resultado.

4.4 Separación de funciones

4.4.1 Ninguna persona debe autorizar y ejecutar simultáneamente la asignación de un acceso a producción. La autorización corresponde al propietario de la información y la ejecución al DBA.

> ***Verificación:*** *Solicitud de acceso firmada por el propietario y registro de ejecución a nombre del DBA, con fechas distinguibles.*

4.4.2 El personal de desarrollo no debe contar con permisos de modificación de datos ni de estructura sobre el ambiente de producción.

> ***Verificación:*** *Inventario de permisos de producción, en el que ninguna cuenta de desarrollo figure con permisos de escritura o de definición de datos.*

4.4.3 Las cuentas con privilegios administrativos sobre la instancia deben ser nominativas y de uso exclusivo para tareas de administración. No deben utilizarse para operación normal, conexión de aplicaciones ni ejecución de consultas de negocio.

> ***Verificación:*** *Listado de miembros de los roles administrativos de servidor, contrastado contra el registro de personal autorizado.*

4.4.4 Ningún control debe ser verificado exclusivamente por el rol que lo ejecuta. Toda actividad de verificación debe tener su responsabilidad final asignada a un rol distinto del ejecutor.

> ***Verificación:*** *Matriz RACI del apartado 4.6, en la que ninguna actividad de verificación concentre R y A en el mismo rol.*

4.5 Procedimiento de excepciones

Cuando una disposición no pueda cumplirse por una limitación técnica, contractual o de edición del producto, debe aplicarse el procedimiento de la tabla 5. Ninguna excepción puede ser tácita.

Paso	Actividad	Responsable	Evidencia
1	Registro de la excepción	DBA	Solicitud con la disposición incumplida, la causa técnica y la duración prevista.
2	Evaluación del riesgo residual	DBA y propietario de la información	Descripción del riesgo que se asume y del escenario en que se materializaría.
3	Definición del control compensatorio	DBA	Control alterno que reduce el riesgo, con su propia evidencia verificable.
4	Aprobación	Jefatura de Tecnologías de Información	Autorización formal con fecha de vencimiento.
5	Revisión de vigencia	DBA	Revisión al vencimiento: se renueva, se subsana o se cierra.

Tabla 5. Procedimiento para el registro y aprobación de excepciones.

> **Criterio:** una excepción aprobada no exime del control. Sustituye un control por otro de efecto equivalente y deja constancia del riesgo asumido. La limitación debe verificarse contra la documentación de la versión concreta del producto, y no inferirse del nombre de la edición.

4.6 Matriz RACI

La tabla 6 asigna las responsabilidades de las actividades principales. Se aplica la notación R para quien ejecuta, A para quien responde por el resultado y aprueba, C para quien es consultado previamente e I para quien es informado. Cada actividad tiene una única asignación de responsabilidad final.

Actividad	DBA	Equipo de desarrollo	Propietario de la información	Jefatura de TI
Creación de bases de datos	R	C	A	I
Asignación y revocación de accesos	R	C	A	I

Actividad	DBA	Equipo de desarrollo	Propietario de la información	Jefatura de TI
Ejecución del respaldo	R / A	I	C	I
Verificación del respaldo y de las pruebas de restauración	R	I	C	A
Restauración y recuperación	R	C	A	I
Cambios en producción	R	C	A	I
Atención de incidentes	R	C	I	A

Tabla 6. Matriz RACI de las actividades principales de administración de bases de datos.

Nota sobre el desdoblamiento de la actividad de respaldo. La ejecución y la verificación del respaldo figuran como actividades separadas y con responsabilidad final distinta, en aplicación de la disposición 4.4.4. Concentrar ambas en el DBA convertiría la verificación en autocontrol: el mismo rol que ejecuta el respaldo declararía que el respaldo es correcto, sin que ningún otro rol responda por esa declaración. El propietario de la información es consultado en ambas actividades porque de su clasificación de criticidad derivan la frecuencia y la retención exigibles.

5. Seguridad y control de acceso

5.1 Creación de logins y usuarios

5.1.1 Todo acceso a una instancia debe materializarse mediante un login de servidor y un usuario de base de datos nominativos, asociados a una persona identificable o a una cuenta de servicio con propietario designado.

> ***Verificación:*** *Inventario de logins y usuarios en el que cada registro tenga una persona o un propietario responsable asignado.*

5.1.2 Debería preferirse la autenticación integrada del sistema operativo sobre la autenticación propia del motor. Cuando se utilice autenticación del motor, deben aplicarse las directivas de complejidad y caducidad de contraseñas del sistema operativo.

> ***Verificación:*** *Consulta del catálogo de logins que muestre el tipo de autenticación y el estado de las opciones de directiva de contraseña.*

5.1.3 Los usuarios y las cuentas de servicio que dejen de requerir acceso deben deshabilitarse dentro de los cinco días hábiles siguientes a la notificación de su desvinculación o cambio de funciones, y eliminarse una vez cerrado el período de retención de registros aplicable.

> ***Verificación:*** *Registro de bajas con fecha de notificación y fecha de deshabilitación efectiva.*

> **Justificación del plazo:** una cuenta activa perteneciente a una persona desvinculada es una credencial válida sin titular responsable, y por tanto el vector de acceso no autorizado con mayor probabilidad de pasar inadvertido. El plazo de cinco días hábiles se fija por ser el máximo que garantiza que toda baja quede cubierta por la revisión ordinaria de accesos sin depender de una notificación inmediata del área de personal. Es una decisión organizacional revisable en la revisión anual del estándar.

5.2 Uso de roles

5.2.1 Los permisos deben asignarse a roles de base de datos y no a usuarios individuales. La asignación directa a un usuario únicamente procede mediante excepción aprobada conforme al apartado 4.5.

> ***Verificación:*** *Inventario de permisos en el que ninguna concesión tenga como beneficiario un usuario, salvo las amparadas por excepción vigente.*

5.2.2 Deben definirse roles por dominio funcional y por nivel de operación, diferenciando como mínimo un perfil de consulta y un perfil de gestión. Cada rol debe declarar por escrito el conjunto de objetos y operaciones que habilita.

> ***Verificación:*** *Matriz de roles y permisos aprobada por el propietario de la información.*

5.2.3 No deben utilizarse los roles fijos de base de datos de alcance amplio para resolver los accesos de usuarios de negocio. Su uso queda restringido a tareas de administración debidamente justificadas.

> ***Verificación:*** *Consulta de membresías de roles fijos, contrastada contra la lista de administradores autorizados.*

> **Fundamento:** un rol de alcance amplio concede permisos sobre objetos que aún no existen. Cualquier tabla creada con posterioridad queda accesible sin que medie decisión alguna, lo que hace imposible sostener el principio de mínimo privilegio en el tiempo.

5.3 Principio de mínimo privilegio

5.3.1 Todo permiso debe concederse únicamente sobre los objetos y las operaciones que la función del usuario requiera de forma demostrable. La ausencia de una necesidad documentada equivale a la ausencia de permiso.

> ***Verificación:*** *Solicitud de acceso que indique la función y la justificación de cada permiso solicitado.*

5.3.2 Las dependencias entre dominios funcionales deben concederse de forma explícita y acotada al conjunto de objetos requerido. No deben resolverse ampliando el alcance del rol solicitante.

> ***Verificación:*** *Matriz de permisos en la que cada acceso a un objeto de otro dominio figure de forma individual y con su justificación.*

5.3.3 Cuando el requerimiento funcional se limite a un subconjunto de atributos de una tabla, el permiso debe otorgarse a nivel de columna o mediante una vista de seguridad, y no sobre la totalidad de la tabla.

> ***Verificación:*** *Prueba de acceso en la que el usuario consulte los atributos autorizados con éxito y reciba un error de permisos al invocar un atributo excluido.*

5.4 Cuentas personales y cuentas compartidas

5.4.1 No debe compartirse una cuenta personal entre dos o más personas, ni utilizarse cuentas genéricas para operación individual.

> ***Verificación:*** *Inventario de cuentas en el que cada cuenta de persona tenga un único titular declarado.*

5.4.2 Las cuentas de servicio deben ser de uso exclusivo de la aplicación para la que fueron creadas, no deben utilizarse por personas para conexión interactiva y deben tener un propietario funcional designado.

> ***Verificación:*** *Registro de cuentas de servicio con aplicación asociada y propietario, más revisión de sesiones interactivas.*

5.5 Revisión y revocación periódica de accesos

5.5.1 Los accesos al ambiente de producción deben revisarse al menos una vez por trimestre por el DBA en conjunto con el propietario de la información. La revisión debe abarcar la vigencia del acceso, la membresía de roles y la pertinencia de cada permiso.

> ***Verificación:*** *Acta de revisión trimestral firmada, con la matriz de permisos vigente adjunta y la lista de revocaciones ejecutadas.*

5.5.2 Todo acceso identificado como innecesario debe revocarse dentro de los cinco días hábiles siguientes a la revisión.

> ***Verificación:*** *Registro de revocación con fecha de detección y fecha de ejecución.*

5.6 Protección de credenciales

5.6.1 Las credenciales no deben incorporarse en el código fuente, en scripts, en archivos de configuración sin protección ni en documentación operativa.

> ***Verificación:*** *Revisión del repositorio de código mediante búsqueda de patrones de credenciales, con resultado documentado.*

5.6.2 Las credenciales de cuentas administrativas y de servicio deben custodiarse en un gestor de secretos con control de acceso y registro de consultas.

Verificación: *Registro de accesos del gestor de secretos.*

5.7 Información sensible

5.7.1 El propietario de la información debe identificar y documentar los atributos que constituyen información sensible en cada base de datos. Dicha identificación debe mantenerse actualizada y es insumo obligatorio de la matriz de permisos.

Verificación: *Inventario de atributos sensibles, con fecha de última actualización y aprobación del propietario.*

5.7.2 El acceso a atributos sensibles debe restringirse a los perfiles que lo requieran para el ejercicio de sus funciones, y debe implementarse conforme a la disposición 5.3.3.

Verificación: *Prueba documentada de acceso permitido y de acceso denegado sobre cada atributo sensible identificado.*

5.8 Auditoría de accesos y cambios administrativos

5.8.1 Deben registrarse como mínimo las operaciones de modificación sobre atributos sensibles, las operaciones sobre información de carácter financiero y los cambios de membresía de roles de base de datos.

Verificación: *Consulta del registro de auditoría que muestre, por cada categoría, al menos un evento con usuario, fecha y hora, objeto y operación.*

5.8.2 El registro de auditoría debe conservarse por un período mínimo de doce meses, con los tres meses más recientes disponibles para consulta inmediata. Su contenido no debe poder ser modificado ni eliminado por los usuarios auditados.

Verificación: *Verificación de los permisos sobre el destino del registro y comprobación de la antigüedad del evento más antiguo conservado.*

> **Justificación del plazo:** los doce meses corresponden al plazo mínimo que establece PCI DSS v4.0 en su requisito 10.5.1 para el historial de registros de auditoría, que exige además que los tres meses más recientes estén disponibles de forma inmediata. Se adopta ese plazo por dos razones: proporciona un fundamento externo verificable en lugar de una cifra arbitraria, y coincide con el ciclo anual de revisión de este estándar, de modo que toda revisión dispone del registro íntegro del período que audita.

5.8.3 Cuando la edición del producto no ofrezca el mecanismo nativo de auditoría, debe implementarse un mecanismo alternativo de cobertura equivalente, tramitado como excepción conforme al apartado 4.5, con declaración expresa de su riesgo residual. La indisponibilidad debe acreditarse contra la documentación de la versión concreta del producto.

Verificación: *Excepción aprobada, constancia de la verificación de indisponibilidad, descripción del mecanismo alternativo y evidencia de eventos capturados por cada categoría exigida.*

5.9 Cifrado: criterios de pertinencia

Este estándar no exige implementar la totalidad de las tecnologías de cifrado disponibles. Exige decidir de forma razonada cuál corresponde a cada situación, conforme a la tabla 7, y dejar constancia de la decisión.

Tecnología	Situación en que resulta pertinente	Limitación que debe conocerse
Cifrado de conexiones	Cuando el tráfico entre la aplicación y la instancia atraviesa una red no confiable o sale del centro de datos.	Protege el dato en tránsito. No protege el dato almacenado ni el respaldo.
Cifrado transparente de datos	Cuando el archivo de datos o el respaldo puede quedar fuera del perímetro físico controlado: equipos portátiles, discos retirados o almacenamiento de terceros.	Protege frente a la sustracción del archivo. No protege frente a un usuario que ya posee permisos válidos sobre la base. No está disponible en todas las ediciones.
Cifrado de respaldos	Cuando las copias se transportan, se replican fuera de sitio o se custodian por un proveedor externo.	Exige un procedimiento de custodia y recuperación de la clave; sin la clave el respaldo es irrecuperable. No está disponible en todas las ediciones.
Protección de columnas sensibles	Cuando un atributo debe permanecer ilegible incluso para el personal administrativo de la plataforma.	Puede impedir la búsqueda, el ordenamiento y la comparación sobre el atributo protegido.

Tabla 7. Criterios de pertinencia de las tecnologías de cifrado.

5.9.1 Para cada base de datos que contenga información sensible debe dejarse constancia escrita de cuál de las tecnologías anteriores se aplica y, cuando no se aplique ninguna, de la razón técnica y del control compensatorio adoptado.

Verificación: *Ficha de decisión de cifrado por base de datos, con fecha y responsable.*

6. Respaldo, restauración y recuperación

6.1 Selección del modelo de recuperación

6.1.1 El modelo de recuperación de cada base de datos debe seleccionarse a partir del objetivo de punto de recuperación aprobado por el propietario de la información, conforme a los criterios de la tabla 8, y no por omisión ni por herencia de la plantilla del sistema.

> ***Verificación:*** *Consulta del catálogo de bases de datos que muestre el modelo vigente, contrastada contra la ficha de criticidad.*

Modelo	Cuándo corresponde	Consecuencia operativa
Completo	Toda base cuyo objetivo de punto de recuperación sea inferior al intervalo entre respaldos completos, o que requiera recuperación a un punto en el tiempo.	Obliga a ejecutar respaldos del registro de transacciones. Si se omiten, el registro crece de forma indefinida hasta agotar el disco.
Con registro masivo	De forma transitoria, durante cargas masivas planificadas sobre una base que opera normalmente en modelo completo.	Durante su vigencia no es posible recuperar a un punto arbitrario dentro del intervalo afectado; solo al final de un respaldo.
Simple	Bases reconstruibles a partir de otra fuente y cuya pérdida desde el último respaldo completo resulte aceptable para el propietario.	No admite respaldos del registro y, por tanto, no permite recuperación a un punto en el tiempo.

Tabla 8. Criterios de selección del modelo de recuperación.

6.2 Tipos de respaldo y frecuencia según criticidad

La criticidad la clasifica el propietario de la información en función del impacto que la pérdida o la indisponibilidad de los datos produce en la operación. Los valores de la tabla 9 son los mínimos exigidos por este estándar; una base concreta puede exigir valores más estrictos, nunca más laxos.

Criticidad	RPO	RTO	Estrategia mínima exigida	Justificación por impacto
Alta	15 minutos	2 horas	Modelo completo. Respaldo completo diario, diferencial cada 6 horas y respaldo de registro cada 15 minutos. Copia fuera de sitio y mecanismo de continuidad.	La detención del proceso interrumpe la operación de cara al cliente o impide facturar. Cada hora de indisponibilidad genera pérdida económica directa o incumplimiento contractual, por lo que el tiempo de reparación debe caber dentro de una jornada parcial.
Media	4 horas	8 horas	Modelo completo. Respaldo completo diario, diferencial diario y respaldo de registro cada 4 horas.	La interrupción degrada procesos internos y obliga a trabajo manual de contingencia, pero no detiene la atención al cliente. La reconstrucción de hasta cuatro horas de trabajo es asumible con esfuerzo administrativo acotado.
Baja	24 horas	72 horas	Modelo simple o completo según el caso. Respaldo completo diario y restauración manual verificada.	Corresponde a información de consulta, histórica o reconstruible desde otra fuente. Su indisponibilidad temporal no afecta procesos productivos, por lo que no se justifica el costo de una cadena de registro continua.

Tabla 9. Objetivos de recuperación y estrategia mínima según criticidad.

> **Criterio:** los valores de objetivo de punto de recuperación y de tiempo de recuperación deben justificarse por el impacto que la pérdida de datos o la indisponibilidad produce en la operación. No se admiten valores fijados sin ese análisis, aun cuando sean más estrictos que los de la tabla.

6.3 Retención y ubicación de las copias

6.3.1 Debe conservarse como mínimo una cadena completa recuperable de treinta días naturales para las bases de criticidad alta y media, y de siete días para las de criticidad baja, sin perjuicio de los plazos legales o contractuales que resulten superiores.

Verificación: *Inventario de copias con su fecha, contrastado contra el plazo declarado.*

> **Justificación de los plazos:** los treinta días cubren un ciclo completo de cierre mensual, que es el período dentro del cual se detecta la mayoría de las inconsistencias de datos que obligan a recuperar información anterior; una retención inferior dejaría sin cobertura los errores descubiertos durante el cierre. Los siete días de la criticidad baja corresponden a un ciclo semanal de operación, suficiente para información reconstruible desde otra fuente. Ambos son decisiones organizacionales revisables.

6.3.2 Ninguna copia de respaldo debe residir exclusivamente en el mismo volumen físico que aloja los archivos de datos de la base que protege. Toda base de criticidad alta o media debe disponer de al menos una copia en una ubicación distinta del sitio de operación.

Verificación: *Ruta física de las copias y comprobante de la copia fuera de sitio con su fecha.*

6.4 Verificación de ejecución

6.4.1 Toda base de datos de producción debe tener activada la verificación de página mediante suma de verificación. Sin ella, la comprobación exigida en la disposición 6.4.2 no puede verificar el contenido de las páginas.

Verificación: *Consulta del catálogo de bases de datos que muestre la opción de verificación de página en modo de suma de verificación.*

> **Fundamento:** la operación de respaldo verifica la información de nivel de página únicamente si esta existe. Cuando no existe suma de verificación de página ni detección de página rasgada, el respaldo no puede verificar la página, la incluye tal cual y concluye con éxito. Sin la disposición 6.4.1, la disposición 6.4.2 podría cumplirse formalmente sin haber verificado una sola página, lo que la convertiría en un control de eficacia aparente.

6.4.2 Todo respaldo debe ejecutarse con la opción de suma de verificación activa, de modo que la operación falle ante una página dañada en lugar de producir una copia inservible.

Verificación: *Registro histórico de respaldos que muestre el indicador de suma de verificación activo.*

6.4.3 El DBA debe verificar diariamente que los respaldos programados se hayan ejecutado con éxito y que su antigüedad no exceda la frecuencia declarada para la criticidad de la base.

Verificación: *Consulta del historial de respaldos de la instancia con la fecha y hora de la última copia de cada tipo.*

6.4.4 La comprobación de legibilidad del archivo de respaldo es un control complementario y no sustituye la prueba de restauración exigida en el apartado 6.5.

Verificación: *Registro de la comprobación, acompañado del acta de la prueba de restauración correspondiente.*

6.5 Pruebas de restauración

6.5.1 Debe ejecutarse al menos una prueba de restauración completa por semestre para cada base de criticidad alta, y al menos una anual para las de criticidad media. La prueba debe realizarse sobre una base o instancia alterna, nunca sobre la base productiva.

Verificación: *Acta de prueba con fecha, cadena de copias utilizada, tiempo total empleado y resultado de la verificación de integridad.*

6.5.2 Cada prueba debe medir el tiempo real transcurrido desde el inicio de la restauración hasta la disponibilidad de la base, y compararlo con el objetivo de tiempo de recuperación declarado. Si el tiempo medido excede el objetivo, debe registrarse como hallazgo y definirse una acción correctiva con plazo.

Verificación: *Acta de prueba con el tiempo medido, el objetivo declarado y, en su caso, el hallazgo y su plan de acción.*

6.5.3 Toda restauración debe concluir con una verificación de integridad física y lógica de la base restaurada y con una comprobación funcional de los datos por parte del propietario de la información.

Verificación: *Salida de la verificación de integridad sin errores y confirmación escrita del propietario.*

6.6 Recuperación a un punto en el tiempo

6.6.1 Toda base de criticidad alta o media debe admitir la recuperación a un punto arbitrario anterior a un incidente lógico. Ello exige mantener el modelo completo y una cadena de registro ininterrumpida.

Verificación: *Prueba de recuperación a un punto en el tiempo, con la marca temporal utilizada y la comprobación de que el dato erróneo no está presente y el dato válido sí lo está.*

6.6.2 Ante un incidente de origen lógico, la primera acción del DBA debe ser registrar la hora anterior al incidente y ejecutar un respaldo del registro de transacciones, antes de cualquier intento de corrección.

Verificación: *Bitácora del incidente con la marca temporal registrada y el comprobante del respaldo de registro posterior al incidente.*

> **Fundamento:** la recuperación a un punto en el tiempo requiere el registro de transacciones que contiene el propio error. Si se corrige o se reinicia la base antes de respaldar ese registro, se pierde el tramo que permite detener la recuperación justo antes del daño.

6.7 Responsables y evidencias

La tabla 10 resume la asignación operativa del proceso de respaldo, en concordancia con la matriz RACI del apartado 4.6.

Actividad	Responsable	Frecuencia	Evidencia
Ejecución del respaldo	DBA	Según criticidad	Historial de respaldos de la instancia
Verificación de ejecución	DBA, con responsabilidad final de la Jefatura de TI	Diaria	Consulta del historial con fecha y hora
Prueba de restauración	DBA, con responsabilidad final de la Jefatura de TI	Semestral o anual	Acta de prueba con tiempo medido
Aprobación de RPO y RTO	Propietario de la información	Anual	Ficha de criticidad firmada
Custodia de copias fuera de sitio	DBA	Según criticidad	Comprobante de traslado o replicación

Tabla 10. Responsables, frecuencias y evidencias del proceso de respaldo.

7. Alta disponibilidad y continuidad

7.1 Diferenciación de conceptos

Los tres conceptos de la tabla 11 atienden riesgos distintos y no son intercambiables. Confundirlos produce arquitecturas costosas que, llegado el incidente, no recuperan la información.

Concepto	Riesgo que atiende	Riesgo que NO atiende
Respaldo	Pérdida o corrupción de los datos: error lógico, borrado accidental, daño físico del almacenamiento.	La indisponibilidad del servicio mientras dura la restauración.
Alta disponibilidad	Indisponibilidad del servicio por falla de un componente dentro del mismo sitio.	El error lógico, que se propaga a la réplica; y la pérdida del sitio completo.
Recuperación ante desastres	Pérdida del sitio de operación completo.	El error lógico, si la replicación es síncrona o de baja latencia.

Tabla 11. Diferenciación entre respaldo, alta disponibilidad y recuperación ante desastres.

7.1.1 Una réplica no constituye un respaldo y no sustituye la obligación de respaldar. Ninguna base debe reducir su estrategia de respaldo por contar con un mecanismo de replicación.

> ***Verificación:*** *Ficha de arquitectura de cada base en la que consten simultáneamente el mecanismo de disponibilidad y la estrategia de respaldo vigente.*

> **Fundamento:** un borrado erróneo ejecutado por una transacción válida se replica en segundos a todas las réplicas, porque la sincronización transmite los registros del propio log. Un grupo de disponibilidad tampoco conmuta ante un problema lógico de la base. La única fuente que conserva el estado anterior es la copia de respaldo.

7.2 Criterios de selección

La selección de una alternativa de disponibilidad debe fundamentarse en los seis criterios siguientes, evaluados de forma conjunta y documentada:

- Criticidad de la información, clasificada por el propietario.
- Objetivo de punto de recuperación exigido.
- Objetivo de tiempo de recuperación exigido.
- Costo total, incluyendo licenciamiento, infraestructura y enlaces de comunicación.
- Infraestructura disponible: red, almacenamiento compartido y sitios alternos.
- Capacidad técnica del equipo para operar y probar la solución de forma sostenida.

7.2.1 La alternativa seleccionada para cada base debe documentarse con la evaluación de los seis criterios anteriores. Una solución que el equipo no pueda probar periódicamente no debe considerarse una alternativa válida.

> ***Verificación:*** *Ficha de decisión de arquitectura por base, con la evaluación de criterios y la fecha de la última prueba de conmutación.*

7.3 Matriz comparativa de alternativas

Este estándar no exige diseñar una arquitectura completa. Exige conocer, conforme a la tabla 12, en qué escenario procede cada alternativa, qué aporta y qué no resuelve. La disponibilidad de cada alternativa depende de la edición desplegada y debe verificarse contra la documentación de la versión concreta.

Alternativa	Escenario de uso	Ventajas principales	Limitaciones
Grupos de disponibilidad Always On	Bases críticas que requieren conmutación automática y, opcionalmente, réplicas legibles o en un sitio alterno.	Conmutación automática. Réplicas en sitio remoto. Posibilidad de descargar consultas de lectura.	Solo edición Enterprise. Mayor complejidad operativa. No protege del error lógico ni conmuta ante él.
Instancias de clúster de conmutación por error	Protección frente a la falla del servidor dentro de un mismo sitio, con instancia única y almacenamiento compartido.	Conmuta la instancia completa, con todas sus bases y objetos de servidor. Operación transparente para la aplicación.	Ediciones Standard y Enterprise. El almacenamiento compartido es punto único de falla. No protege el sitio ni ofrece réplica legible.
Trasvase de registros	Sitio alterno con tolerancia de minutos, o necesidad de una copia con retraso deliberado.	Bajo costo y baja complejidad. El retraso configurable en la restauración protege del error lógico. Lectura limitada en la secundaria en estado de espera.	Ediciones Web, Standard y Enterprise; no disponible en Express. Conmutación manual. Pérdida potencial de hasta un intervalo de envío. La secundaria no admite escritura.
Restauración desde respaldos	Bases de criticidad baja, o como mecanismo de última instancia para cualquier base.	Costo mínimo y disponible en todas las ediciones. Es el único mecanismo que recupera de un error lógico y de la corrupción propagada.	El tiempo de recuperación es el más alto de las cuatro alternativas y depende del tamaño de la base.

Tabla 12. Matriz comparativa de alternativas de disponibilidad y continuidad.

8. Monitoreo y mantenimiento

8.1 Línea base de salud operativa

8.1.1 Cada instancia debe disponer de una línea base documentada que incluya, como mínimo: estado y modelo de recuperación de las bases, tamaño y espacio disponible de los archivos de datos y de registro, uso del registro de transacciones, sesiones y solicitudes activas, transacciones abiertas y bloqueos presentes, y antigüedad del último respaldo de cada tipo.

> ***Verificación:*** *Documento de línea base con la fecha de captura, los valores obtenidos y su interpretación escrita.*

8.1.2 La línea base debe actualizarse al menos semestralmente y tras todo cambio relevante de infraestructura, volumen de datos o carga de trabajo.

> ***Verificación:*** *Versiones fechadas de la línea base y registro del cambio que motivó cada actualización.*

8.2 Vigilancia de capacidad

8.2.1 El DBA debe verificar semanalmente el crecimiento de los archivos de datos y de registro, así como el espacio disponible en los volúmenes que los alojan. Debe emitirse una alerta cuando el espacio libre del volumen descienda por debajo del veinte por ciento.

Verificación: *Registro semanal de espacio con fecha y valores, y constancia de las alertas emitidas.*

> **Justificación del umbral:** con incrementos de crecimiento de tamaño fijo, un margen del veinte por ciento garantiza al menos tres eventos de crecimiento antes del agotamiento del volumen. Ese margen es el que permite tramitar y ejecutar una ampliación de almacenamiento dentro de un ciclo semanal de vigilancia sin llegar a la detención del servicio. Es una decisión organizacional que debe revisarse si cambia el incremento de crecimiento o la frecuencia de vigilancia.

8.2.2 Los archivos de datos y de registro deben configurarse con incrementos de crecimiento de tamaño fijo. El crecimiento porcentual únicamente procede mediante justificación técnica documentada.

Verificación: *Consulta de la configuración de archivos que muestre el tipo y el valor del incremento de cada archivo.*

8.3 Mantenimiento preventivo

8.3.1 Debe ejecutarse una verificación de integridad física y lógica sobre cada base de producción con periodicidad al menos semanal. Todo error detectado debe tratarse como incidente de severidad alta.

Verificación: *Salida de la verificación con fecha, o registro del incidente abierto cuando corresponda.*

8.3.2 Debe mantenerse un plan de actualización de estadísticas y de tratamiento de la fragmentación de índices, cuya periodicidad se determine a partir de la volatilidad de los datos de cada base.

Verificación: *Plan documentado y registro de ejecución con fecha.*

8.4 Atención de incidentes

8.4.1 Todo incidente que afecte la disponibilidad o la integridad de una base de datos debe registrarse en una bitácora que consigne: hora de detección, hora de inicio de la atención, diagnóstico, acciones ejecutadas, hora de restablecimiento y causa raíz identificada.

Verificación: *Bitácora del incidente completa, con las marcas temporales exigidas.*

8.4.2 Los incidentes que hayan requerido una restauración deben dar lugar a la revisión de los objetivos de recuperación de la base afectada dentro de los treinta días naturales siguientes.

Verificación: *Acta de revisión con la comparación entre el tiempo real de recuperación y el objetivo declarado.*

9. Convenciones de código y gestión de cambios

9.1 Nomenclatura

9.1.1 Los nombres de bases de datos, esquemas, objetos y restricciones deben ajustarse a la tabla 13. Los nombres deben ser descriptivos, sin abreviaturas no documentadas, sin espacios y sin caracteres que obliguen a delimitadores.

> ***Verificación:*** *Revisión de nomenclatura sobre el catálogo de objetos previa a cada despliegue, con resultado registrado.*

Elemento	Convención	Ejemplo
Base de datos	Prefijo DB seguido del nombre del sistema o dominio, en notación de mayúscula inicial por palabra.	DBGestionAcademica
Esquema	Nombre del dominio funcional en minúscula y en singular.	inventario
Tabla	Sustantivo en singular, mayúscula inicial por palabra, calificado siempre por su esquema.	inventario.Movimiento
Columna	Mayúscula inicial por palabra, sin prefijo de tipo ni repetición del nombre de la tabla.	FechaMovimiento
Llave primaria	PK_ seguido del nombre de la tabla.	PK_Movimiento
Llave foránea	FK_ seguido de la tabla origen y la tabla referenciada.	FK_Movimiento_Producto
Restricción de unicidad	UQ_ seguido de la tabla y las columnas.	UQ_Producto_Codigo
Restricción de verificación	CK_ seguido de la tabla y la columna o regla.	CK_Movimiento_Cantidad
Valor por omisión	DF_ seguido de la tabla y la columna.	DF_Movimiento_Fecha
Índice	IX_ seguido de la tabla y las columnas clave.	IX_Movimiento_FechaProducto
Vista	vw_ seguido del propósito, calificada por esquema.	inventario.vw_ExistenciaActual
Procedimiento almacenado	usp_ seguido de verbo y objeto.	usp_RegistrarMovimiento
Función	ufn_ seguido del valor que retorna.	ufn_CalcularExistencia
Desencadenador	tr_ seguido de la tabla y el evento.	tr_Movimiento_AfterInsert
Parámetro	Prefijo @p seguido del nombre descriptivo.	@pProductoID
Variable	Prefijo @ seguido del nombre descriptivo.	@totalRegistros
Tabla temporal	Prefijo #tmp seguido del contenido.	#tmpMovimientoDia

Tabla 13. Convenciones de nomenclatura de objetos de base de datos.

9.2 Reglas de código T-SQL

9.2.1 Toda referencia a un objeto debe calificarse mediante su esquema. No se admiten referencias basadas en el esquema por omisión del usuario.

Verificación: *Revisión de código previa al despliegue; ninguna referencia a objeto sin calificar.*

9.2.2 No debe utilizarse la proyección de todas las columnas en código productivo. Las columnas deben declararse de forma explícita, tanto en la proyección como en las operaciones de inserción.

Verificación: *Revisión de código previa al despliegue; ausencia del patrón en objetos productivos.*

9.2.3 Los tipos de datos deben seleccionarse por la naturaleza y el dominio del atributo. No deben emplearse tipos de longitud superior a la requerida ni tipos de texto genéricos para almacenar valores numéricos, fechas o identificadores.

Verificación: *Revisión del diccionario de datos frente a la definición física de las tablas.*

9.2.4 Las consultas y los procedimientos que reciban valores externos deben parametrizarse. No deben construirse sentencias mediante concatenación de valores proporcionados por el usuario.

Verificación: *Revisión de código; toda entrada externa debe viajar como parámetro.*

9.2.5 El código dinámico debe limitarse a los casos en que la estructura de la sentencia no pueda resolverse de otro modo. Cuando se utilice, debe ejecutarse mediante el procedimiento del sistema que admite parámetros tipados.

Verificación: *Justificación documentada por cada objeto que emplee código dinámico.*

9.2.6 Los procedimientos que ejecuten operaciones de modificación deben implementar manejo estructurado de errores y relanzar la condición de error con su severidad original tras revertir la transacción.

Verificación: *Inspección del objeto; presencia del bloque de manejo de errores y de la relanzación.*

9.2.7 Las transacciones deben abarcar únicamente las operaciones que deban confirmarse o revertirse de forma conjunta. No deben mantenerse transacciones abiertas a la espera de interacción del usuario ni de procesos externos.

Verificación: *Consulta de transacciones activas durante el monitoreo; ausencia de transacciones abiertas prolongadas.*

9.2.8 Debería favorecerse la programación orientada a conjuntos. El recorrido fila por fila se admite únicamente cuando la operación no pueda expresarse en conjuntos, con justificación documentada.

Verificación: *Revisión de código y justificación por cada recorrido iterativo presente.*

9.2.9 Cada objeto debe incluir un encabezado con su propósito, autor, fecha, versión y dependencias. Los comentarios internos deben explicar las decisiones no evidentes y no repetir lo que la sentencia ya expresa.

Verificación: *Inspección del objeto; presencia del encabezado completo.*

9.3 Control de versiones y despliegues

9.3.1 Todo script que modifique una base de datos debe residir en el repositorio oficial de la organización. No se admiten cambios aplicados desde archivos locales o adjuntos de correo.

Verificación: *Trazabilidad entre el cambio aplicado en producción y su confirmación en el repositorio.*

9.3.2 Cada script debe identificar versión, autor y fecha, y numerarse de modo que su orden de ejecución sea inequívoco.

Verificación: *Inspección del encabezado y de la estructura de nombres del conjunto de scripts.*

9.3.3 Todo cambio debe contar con su script de reversión, entregado y probado junto con el script de implementación.

Verificación: *Existencia del par de scripts y constancia de la prueba de reversión en ambiente inferior.*

9.3.4 Ningún cambio debe ejecutarse en producción sin haberse probado previamente en un ambiente inferior con datos representativos.

Verificación: *Registro de la ejecución previa, con fecha, ambiente y resultado.*

9.3.5 Todo cambio en producción debe ejecutarse dentro de una ventana autorizada, precedido de un respaldo válido de la base afectada, y debe dejar constancia de su ejecución.

Verificación: *Autorización de la ventana, comprobante del respaldo previo y registro de ejecución con fecha y hora.*

9.3.6 Los scripts cuyo efecto sea destructivo deben declarar esa condición en su encabezado y permanecer inhabilitados por omisión.

Verificación: *Inspección del encabezado y del estado del bloque destructivo.*

9.4 Lista de verificación previa al despliegue

El DBA debe aplicar la lista de la tabla 14 antes de autorizar la ejecución de cualquier script sobre el ambiente de producción. Un solo elemento marcado como no conforme impide el despliegue.

N.º	Elemento verificado	Conforme
1	Todos los objetos están calificados por su esquema.	
2	No existe proyección de todas las columnas en el código productivo.	
3	Las columnas están declaradas de forma explícita en las inserciones.	
4	Los tipos de datos corresponden al dominio del atributo y a su longitud real.	
5	Las entradas externas viajan como parámetros; no hay concatenación de valores.	
6	El código dinámico, si existe, está justificado y parametrizado.	
7	Las operaciones de modificación tienen manejo de errores y relanzamiento.	
8	Las transacciones son breves y no dependen de procesos externos.	
9	Las restricciones creadas tienen nombre explícito y consistente.	
10	El encabezado declara propósito, autor, fecha, versión y dependencias.	
11	Existe script de reversión probado.	
12	El cambio fue ejecutado con éxito en un ambiente inferior.	
13	Existe respaldo válido y reciente de la base afectada.	
14	El script no contiene credenciales, rutas personales ni información sensible.	
15	Los bloques destructivos están declarados e inhabilitados por omisión.	

Tabla 14. Lista de verificación de código y despliegue.

10. Catálogo de controles

Los trece controles de la tabla 15 son las obligaciones cuyo cumplimiento se evalúa de forma directa. Cada uno expresa una obligación concreta y admite una determinación binaria de cumplimiento. La distribución por dominio es: gobierno dos, seguridad cuatro, respaldo dos, disponibilidad uno, monitoreo dos y código dos, lo que satisface y supera el mínimo exigible en cada dominio.

DBA-GOB-01 · Gobierno y responsabilidades

Campo	Contenido
Requisito	Toda base de datos en producción debe tener un propietario de la información designado por escrito y un DBA responsable de su operación. La base no debe ponerse en servicio mientras ambos roles no estén asignados.
Responsable	Jefatura de TI
Frecuencia	En la creación y revisión anual
Evidencia	Ficha de la base de datos con ambos roles designados y fecha de designación.

DBA-GOB-02 · Gobierno y responsabilidades

Campo	Contenido
Requisito	Toda desviación respecto de este estándar debe tramitarse como excepción formal, con riesgo residual evaluado, control compensatorio definido y fecha de vencimiento. No se admiten desviaciones tácitas. La limitación invocada debe acreditarse contra la documentación de la versión concreta del producto.
Responsable	DBA
Frecuencia	Por evento y revisión al vencimiento
Evidencia	Registro de excepciones con aprobación de la jefatura de TI, constancia de la verificación de la limitación y estado de vigencia.

DBA-SEG-01 · Seguridad

Campo	Contenido
Requisito	Los permisos deben asignarse mediante roles de base de datos y no directamente a usuarios individuales. El DBA debe revisar los accesos de producción al menos una vez por trimestre y conservar la matriz de permisos como evidencia.
Responsable	DBA
Frecuencia	Trimestral
Evidencia	Matriz de permisos vigente y acta de revisión trimestral firmada por el propietario de la información.

DBA-SEG-02 · Seguridad

Campo	Contenido
Requisito	No deben utilizarse roles fijos de base de datos de alcance amplio para resolver accesos de usuarios de negocio. La membresía de los roles administrativos debe limitarse al personal autorizado por escrito.
Responsable	DBA
Frecuencia	Trimestral
Evidencia	Consulta de membresías de roles fijos contrastada con la lista de administradores autorizados.

DBA-SEG-03 · Seguridad

Campo	Contenido
Requisito	Los atributos clasificados como sensibles deben protegerse mediante permisos a nivel de columna o vistas de seguridad. Debe demostrarse, por cada atributo sensible, un acceso permitido y un acceso denegado.
Responsable	DBA
Frecuencia	En cada cambio de la matriz y revisión trimestral
Evidencia	Prueba documentada de acceso permitido y de acceso denegado, con el mensaje de error obtenido.

DBA-SEG-04 · Seguridad

Campo	Contenido
Requisito	Deben auditarse las modificaciones sobre atributos sensibles, las operaciones sobre información financiera y los cambios de membresía de roles. Cada evento debe registrar usuario, fecha y hora, objeto y operación, y conservarse doce meses con los tres más recientes de consulta inmediata.
Responsable	DBA
Frecuencia	Registro continuo; revisión mensual
Evidencia	Consulta del registro de auditoría con al menos un evento por categoría y verificación de la antigüedad conservada.

DBA-BKP-01 · Respaldo y recuperación

Campo	Contenido
Requisito	Cada base debe contar con un modelo de recuperación y una cadena de respaldos acordes con su criticidad. El DBA debe verificar diariamente la ejecución de los respaldos programados y su antigüedad, y la Jefatura de TI responde por esa verificación.
Responsable	DBA; responsabilidad final de la Jefatura de TI
Frecuencia	Diaria
Evidencia	Consulta del historial de respaldos de la instancia con fecha, hora y tipo de la última copia de cada clase.

DBA-BKP-02 · Respaldo y recuperación

Campo	Contenido
Requisito	Debe ejecutarse una prueba de restauración sobre base alterna al menos semestralmente para las bases de criticidad alta, midiendo el tiempo real de recuperación, comparándolo con el objetivo declarado y verificando la integridad de la base restaurada. La verificación de página por suma de verificación debe estar activa en la base de origen.
Responsable	DBA; responsabilidad final de la Jefatura de TI
Frecuencia	Semestral
Evidencia	Acta de prueba con cadena utilizada, tiempo medido, objetivo declarado, salida de la verificación de integridad y constancia de la opción de verificación de página.

DBA-DIS-01 · Disponibilidad y continuidad

Campo	Contenido
Requisito	Ninguna base debe reducir su estrategia de respaldo por contar con un mecanismo de replicación. La alternativa de disponibilidad de cada base debe documentarse con la evaluación de los seis criterios del apartado 7.2.
Responsable	DBA
Frecuencia	Anual y ante cambio de arquitectura
Evidencia	Ficha de arquitectura con la evaluación de criterios y la estrategia de respaldo vigente coexistiendo.

DBA-MON-01 · Monitoreo y mantenimiento

Campo	Contenido
Requisito	Cada instancia debe mantener una línea base de salud operativa documentada e interpretada, actualizada al menos semestralmente y tras todo cambio relevante de infraestructura o carga.
Responsable	DBA
Frecuencia	Semestral
Evidencia	Documento de línea base con fecha de captura, valores obtenidos e interpretación escrita.

DBA-MON-02 · Monitoreo y mantenimiento

Campo	Contenido
Requisito	El DBA debe verificar semanalmente el crecimiento de los archivos de datos y de registro y el espacio disponible en sus volúmenes, y emitir alerta cuando el espacio libre descienda por debajo del veinte por ciento.
Responsable	DBA
Frecuencia	Semanal
Evidencia	Registro semanal de espacio con fecha y valores, y constancia de las alertas emitidas.

DBA-COD-01 · Código y gestión de cambios

Campo	Contenido
Requisito	Todo objeto debe referenciarse calificado por su esquema y no debe admitirse la proyección de todas las columnas en código productivo. El DBA debe aplicar la lista de verificación de la tabla 14 antes de autorizar el despliegue.
Responsable	DBA
Frecuencia	En cada despliegue
Evidencia	Lista de verificación completada y firmada por despliegue.

DBA-COD-02 · Código y gestión de cambios

Campo	Contenido
Requisito	Todo cambio en producción debe contar con script de implementación y de reversión versionados en el repositorio oficial, probados en ambiente inferior, precedidos de respaldo válido y libres de credenciales incrustadas.
Responsable	DBA
Frecuencia	En cada despliegue
Evidencia	Confirmación en el repositorio, registro de la prueba previa, comprobante del respaldo y registro de ejecución.

Tabla 15. Catálogo de controles verificables del estándar.

11. Control de versiones y aprobación

11.1 Control de versiones

La tabla 16 registra el historial de versiones exigido por la disposición 1.5.2.

Versión	Fecha	Autor	Naturaleza del cambio
1.0	29/08/2026	Equipo consultor DBA	Emisión inicial del estándar.
1.1	29/08/2026	Equipo consultor DBA	Incorporación de las cláusulas de referencias normativas y de términos, definiciones y formas verbales. Desdoblamiento de la actividad de respaldo en la matriz RACI con responsabilidad final distinta. Nueva disposición sobre verificación de página. Justificación de los plazos y umbrales. Reclasificación del control de auditoría como DBA-SEG-04. Actualización de las referencias con edición y versión.

Tabla 16. Control de versiones del estándar.

11.2 Aprobación

La vigencia de este estándar queda condicionada, conforme a la disposición 1.5.1, al registro completo de la tabla 17.

Actuación	Rol	Nombre y fecha	Firma
Elaboró	Equipo consultor DBA		
Revisó	Administrador de bases de datos		
Aprobó	Jefatura de Tecnologías de Información		

Tabla 17. Registro de elaboración, revisión y aprobación del estándar.